

# Lección 13 - Análisis estático y recuperación autorizada

## Caracterizar un archivo sin ejecutarlo

Gemini Notebook

# La capacidad potencial NO es comportamiento observado.

## ¿Qué puede afirmarse de un archivo sin ejecutarlo y dónde termina esa certeza?

### Mirar no es ejecutar

Inspeccionar la estructura no detona la amenaza.

### Un indicador no es un veredicto

Encontrar una pista no prueba un crimen.

### El límite es el alcance

Tu autorización marca la frontera absoluta de la acción.

### Capacidad no es comportamiento

Que un archivo pueda hacer algo no demuestra que lo haga.

## Análisis Estático

**Definición:** Examen de un archivo a partir de sus bytes, sin ejecutarlo.
**Ejemplo:** Extraer cadenas de texto de un binario sospechoso.
**Qué NO permite afirmar:** Que el archivo efectivamente realizará acciones maliciosas en un sistema vivo.

Gemini Notebook

# Análisis estático y análisis dinámico

| 📘 Análisis Estático | 🚨 Análisis Dinámico |
| --- | --- |
| **Qué hace:** Analiza estructura, código y metadatos. | **Qué hace:** Observa el comportamiento en vivo y en tiempo real. |
| **Qué responde:** ¿Qué es, qué contiene, qué podría hacer? | **Qué responde:** ¿Qué hace realmente al ejecutarse? |
| **Riesgo:** Bajo: el archivo no actúa | **Riesgo:** Alto (requiere contención estricta). |
| **Límite**: No ve comportamiento; la ofuscación puede ocultar cadenas | **Requisitos estrictos:** Máquina virtual desechable, snapshot previo, red aislada, y garantía de reversión. |

## ¿Por qué primero el estático?

Primero el estático: es más seguro y orienta qué buscar al ejecutar. El dinámico se diseña ahora y se ejecuta en la Lección 14.

Gemini Notebook

## Manejo seguro de la muestra (NIST SP 800-83)

**Definición:** Medidas para evitar la propagación o ejecución accidental de una muestra.
**Ejemplo:** analizar la muestra en una estación sin red y sobre una copia de solo lectura.
**Qué NO permite afirmar:** Contener no dice nada sobre qué hace la muestra; solo evita que actúe o se propague.

## Reglas de Oro (NIST SP 800-83)



**Contener y Aislar:** Desconectar de la red inmediatamente.



**Jamás ejecutar ni renombrar:** Renombrarla puede hacer que el sistema la asocie a un programa y la abra.

# NUNCA SUBIR A SERVICIOS PÚBLICOS

(ej. VirusTotal)

**Razón:** Distribuye la muestra: puede quedar indexada y filtrar información del caso.

Gemini Notebook

## Tipo real: la firma manda, no la extensión

**Definición:** Constante numérica en los primeros bytes de un archivo que identifica su formato real.

**Ejemplo:** `4D 5A` para ejecutables de Windows.

**Qué NO permite afirmar:** Que el archivo sea malicioso ni que se haya renombrado con intención, un archivo legítimo también puede estar mal nombrado.

La extensión (ej. `.docx`) es simplemente una etiqueta editable del nombre que cualquiera puede cambiar.

### ANÁLISIS DE ARCHIVO




documento.pdf

### RAW HEX DUMP

```
Offset  0  1  2  3  3  4  5  6  7  8  9  A  B  C  D  E  F

        4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 B8 00
        00 00 00 00 0A 00 00 00 00 00 00 8F 6F 67 5F 0A 00 00
```

| | |
|---|---|
| `4D 5A (MZ)` → Ejecutable Windows (PE) | `7F 45 4C 46 (ELF)` → Ejecutable Linux |
| `25 50 44 46 (%PDF)` → Documento PDF | `FF D8 FF` → Imagen JPEG |
| `50 4B 03 04` → Archivo ZIP / DOCX moderno | **head -c 2 archivo \| od -An -tx1**: muestra los 2 primeros bytes |

**file** archivo: nombra el tipo probable según la firma

**od -An -c** archivo: muestra los mismos bytes como caracteres (`M Z`)

Gemini Notebook

# El hash identifica, no clasifica



instalador.exe

e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855



muestra.exe

8d969eef6ecad3c29a3a629280e686cf0c3f5d5a86aff3ca12020c923adc6c92

Cada archivo tiene su hash; el valor por sí solo no dice cuál es malicioso

## Identidad, no Culpabilidad

Un hash vincula copias exactas, byte por byte. Identifica un contenido exacto, pero NO lo clasifica como malicioso. Dice “es el mismo archivo”, nunca “es malware”.

## Comparar con listas conocidas

Un hash puede compararse con listas de archivos conocidos, buenos o malos. Esa lista es una fuente externa más, con su propia confiabilidad, no una verdad absoluta.

Gemini Notebook

# Metadatos: útiles, pero editables

## Ficha de Archivo

FÁCILMENTE EDITABLE

Tamaño:

Fechas del sistema de archivos:

Autor declarado:

Fecha de compilación:

## Precaución

Un instalador de 2 KB es sospechoso, pero el tamaño solo no concluye nada

## Metadatos de Sistema y Archivo

Atributos que describen propiedades del archivo en lugar de su contenido. Ejemplo: Fecha de compilación de un ejecutable. **Qué NO permite afirmar:** Que esos datos son verídicos, exactos o que reflejan la historia real del archivo.

## Comando stat

stat solo muestra propiedades del sistema de archivos (nombre, tamaño, fecha de modificación). **NO** lee metadatos internos: autor, firma digital ni fecha de compilación

## Axioma Forense

No examinado no es ausente: si la herramienta no lee un campo, se registra 'no examinado', nunca 'ausente'.
Ejemplo: con `stat` no puede afirmarse que el archivo no tenga firma digital

Gemini Notebook

# Strings (Cadenas)

**Definición:** Secuencia de caracteres legibles incrustada en el código binario.
**Ejemplo:** Una dirección IP extraída de un binario.
**Qué NO permite afirmar:** Que el programa ejecute esa secuencia en la realidad.
**strings -n 6 archivo:** extrae secuencias legibles de 6 o más caracteres

## Semáforo Forense

### FUERTE

**HKCU\Software\Microsoft\Windows\CurrentVersion\Run**

**Falso positivo posible:** Un instalador legítimo también registra autoarranque.

### CONTEXTUAL

**WinHttpOpen, RegSetValueExW, CreateFileW**

**Falso positivo posible:** Muchos programas legítimos usan red y registro.

### DÉBIL o SEÑUELO

**kernel32.dll, Microsoft Corporation**

**Falso positivo posible:** Es texto común en casi cualquier software de Windows.

**La Trampa Cognitiva:** Encontrar HKCU\Software\MiEmpresa\Run contiene la palabra Run, pero **NO** es una ruta real de autoarranque del sistema operativo.

Cada indicador se registra con su clase y su falso positivo posible.

Gemini Notebook

# IoC estáticos: potenciales, no probados

```
pagos-sync.cerro-verde.invalid
CreateProcessA
LoadLibraryW
SYSTEM32\drivers\etc\hosts
```

```
$#@!%&X^
[{~§¶½»¼«¬®¯±°²³´µ]
øæåäöàèìòùâêîôûç
+?><;;|/=
ñ¥ðÐ€¢£¥
™¡¢£¤¥¦§¨©ª«¬®¯°±²³´µ¶·¸¹º»¼½¾¿
```

Ofuscación oculta evidencia estática

## El Límite del Indicador

El archivo contiene los indicadores, pero esto no prueba su uso.

## Falsos Positivos

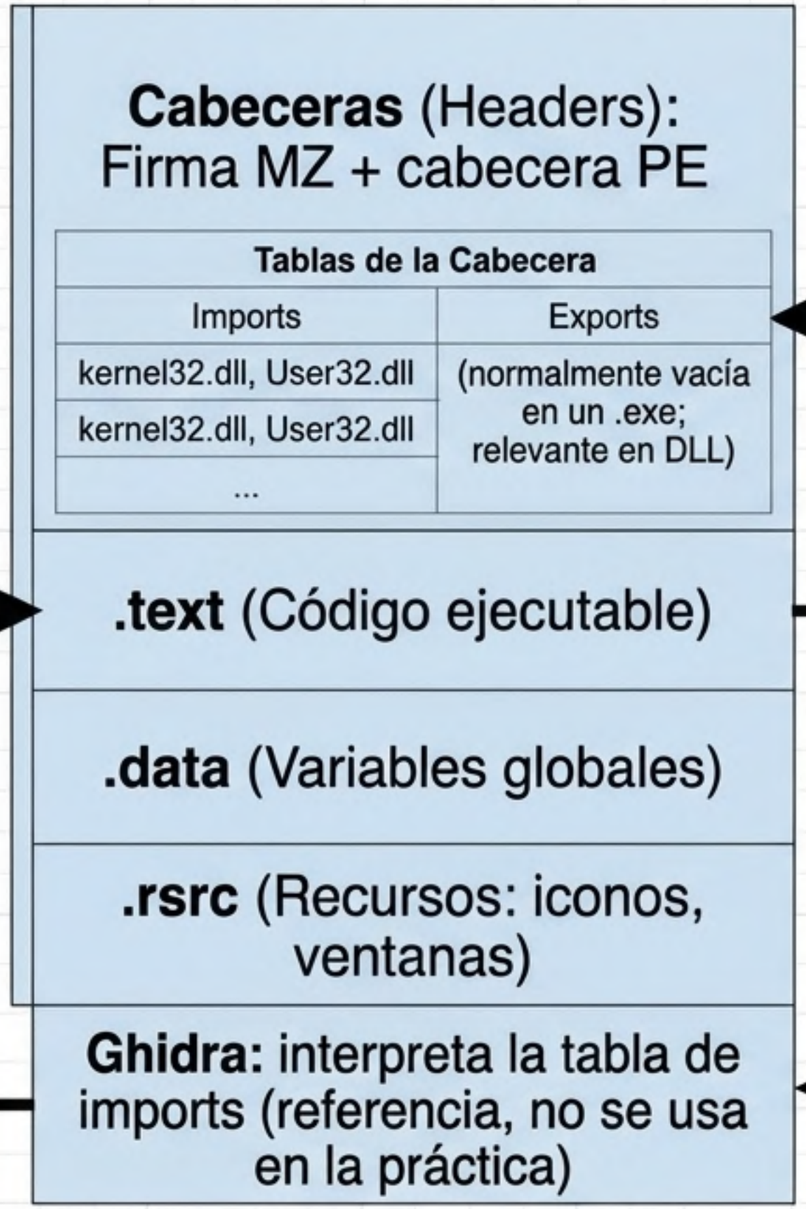
Un dominio incrustado puede ser un señuelo que nunca se contacta; un nombre de API indica que el archivo puede llamar esa función, no que la ejecute. Los dominios .invalid del laboratorio se analizan como reales: no resolver no prueba que sean señuelos.

## La Barrera de la Ofuscación

Técnicas operativas ocultan texto. Regla: No encontrar cadenas de red en análisis estático NO significa que el programa no pueda comunicarse. Es compatible con T1027 (ofuscación)

Gemini Notebook

# Estructura PE (Portable Executable)




**Definición:** PE (Portable Executable) es el formato de los ejecutables de Windows: cabeceras, secciones y tablas de imports y exports.

**Ejemplo:** la sección .text guarda el código; la tabla de imports lista funciones externas como WinHttpOpen.

**Qué NO permite afirmar:** que el código declarado se ejecute ni que las funciones listadas se usen

**strings**

Recorre todo el archivo: halla nombres de sección (`.text`, `.data`, `.rsrc`) y de funciones como texto, sin verificar importación ni uso.

```
strings -n 4 archivo | grep -oE '\.(text|data|rsrc)'
```

**Nota:** Ghidra es referencia; en la práctica se usan `file`, `strings` y `od`

**Frase modelo:** Contiene nombres de funciones de red; su importación y uso no se verificaron

Gemini Notebook

# El Lenguaje Acotado Forense

**Confirmar** una acción exige análisis dinámico u otra evidencia que lo corrobore

Contiene WinHttpOpen → ✓ capacidad: podría comunicarse / ✘ comportamiento: se comunicó (requiere dinámico)

| Uso Incorrecto (X) | Uso Correcto (✓) |
| --- | --- |
| ~~El malware robó datos por red.~~ | El archivo referencia funciones de red / es compatible con conectividad. |
| ~~Se comunicó con el servidor X.~~ | Contiene el indicador de red X en su estructura. |
| ~~Instala un backdoor silencioso.~~ | Hace referencia a rutas compatibles con persistencia. |

**Plantilla de Informe**

- Hipótesis principal (podría / es compatible con)
- Explicación benigna alternativa
- Afirmación que el análisis estático NO permite sostener

Gemini Notebook

# Táctica y Técnica (MITRE ATT&CK)

**Definición:** Táctica es el objetivo (ej. Persistencia TA0003); Técnica es el cómo (ej. modificar el registro).
**Ejemplo:** T1547.001 (Autoarranque).
**Qué NO permite afirmar:** Que la técnica se haya ejecutado: el mapeo estático es una hipótesis basada en capacidad.

| Hallazgo Estático | Técnica MITRE Tentativa | Alternativa Benigna | Redacción |
|---|---|---|---|
| Referencia a rutas de inicio | Autoarranque (T1547.001) - Persistencia TA0003 | Instalador legítimo registrándose. | Contiene el texto de una ubicación de autoarranque, compatible con persistencia; no se verificó que la escriba. |
| Llamadas API web + Dominio | Capa Aplicación Web (T1071.001) - Mando y control TA0011 | Actualizador automático de software. | |
| Extensión inconsistente con magic bytes | Extensión Falsa (T1036.008) - Evasión TA0005 | Archivo legítimo mal nombrado por error. | |
| Cadenas cifradas o ilegibles | Ofuscación (T1027) - Evasión TA0005 | Protección de IP de software comercial. | |
| Funciones de descarga HTTP | Descarga (T1105) - Mando y control TA0011 | Módulo de ayuda en línea. | |

Regla de Mapeo: Justificar SIEMPRE con el indicador, usar formato condicional y no listar técnicas teóricas sin evidencia. Una lista de técnicas candidatas puede incluir algunas que NO corresponden: elegir solo las que respalda un indicador observado

Gemini Notebook

# Recuperación Autorizada

**Definición:** Obtener el contenido de un contenedor protegido probando solo los candidatos autorizados para ese caso.
**Ejemplo:** Descifrar un ZIP corporativo empleando una lista de candidatos entregada por jefatura que autoriza el análisis.
**Qué NO permite afirmar:** Demuestra acceso técnico; NO demuestra autoría, intención ni licitud del poseedor del contenedor.

## Ley 21.459: Mismo comando, distinta legitimidad

| | ⚖ Recuperación Autorizada | ⚠ Fuerza Bruta Abierta |
|---|---|---|
| **Alcance** | Lista cerrada de candidatos preaprobada | Diccionarios amplios o espacio completo de contraseñas. |
| **Autorización** | Explícita, para ese contenedor | Ausente o difusa |
| **Registro** | Herramienta y versión, lista usada, candidatos probados en orden, inicio y término, resultado | Sin registro |
| **Si falla** | Agotar la lista es un resultado válido: se informa y se escala | Se sigue intentando hasta entrar |

**Procedimiento**

Un candidato por vez y en orden: unzip -P 'candidato' contenedor.zip -d salida.
incorrect password → anotar y probar el siguiente.
inflating: ... → detenerse, registrar la hora y calcular el SHA-256

La autorización vale solo para ESE contenedor: no permite probar otros archivos ni cuentas

**Criterio de Validación Técnica:** El **SHA-256** del contenido final extraído DEBE compararse y coincidir exactamente con el esperado.

Gemini Notebook

# Cuándo detenerse y cómo cerrar el análisis

### Criterios de Detención Inmediata:

Detener el análisis ante hash distinto, contenido interno inesperado, o lista autorizada de candidatos agotada (agotarla no autoriza ampliarla).

### Qué demuestra la recuperación y qué NO

Qué demuestra la recuperación: acceso al contenido.
Qué NO: autoría, intención ni licitud.
El SHA-256 confirma que es el documento esperado, no quién lo puso allí.

### Ficha Estándar de Veredicto

[ ] Resultado observado (solo lo que muestran tipo, cadenas y recuperación): .....
[ ] Interpretación (qué significa para la pregunta del caso): .....
[ ] Confianza y Razón: Alta / Media / Baja (basada en la solidez y convergencia de los indicadores).
[ ] Limitación Ineludible: "No ejecutado en entorno dinámico".
[ ] Prueba Dinámica Diseñada (Futura - Sin ejecutar aún):
- Nivel de aislamiento de red: .....
- Monitor de procesos a activar: .....
- Condición de detención: .....
- Reversión al snapshot: .....

Gemini Notebook

## Ejemplo Práctico

**Muestra:** informe-pagos.docx (Falsa extensión)

**Hallazgos Estáticos:**
- **Magic Bytes:** 4D 5A (PE32 Executable)
- **Contiene clave:** HKCU\…\CurrentVersion\Run
- **Dominio:** pagos-sync.cerro-verde.invalid
- **Nombres de funciones (texto):** WinHttpOpen, RegSetValueExW
- **String decoy:** Microsoft Corporation

**Veredicto:**
Confianza media: varios indicadores fuertes coinciden, pero nada se ejecutó.

**Alternativa Benigna:**
Un instalador legítimo con la extensión cambiada por error.

## Errores Fatales en Laboratorio

- ✗ Ejecutar con doble clic “solo para ver qué hace”.
- ✗ Subir el binario a plataformas web públicas (filtra información del caso).
- ✗ Afirmar comportamiento (“Este archivo roba credenciales”).
- ✗ Ampliar la lista de contraseñas de fuerza bruta por cuenta propia sin autorización gerencial.
- ✗ No declarar falsos positivos ni explicaciones alternativas.

Gemini Notebook